

HACKPROVE WORLD WHITEHAT CONFERENCE 2026



HACKPROVE

中国·澳门

分布式攻击实验

挑战 AI 安全中的核心假设

主题 10 独立讲义 中国·澳门

03:25:29–04:02:50

目录

1	本讲义的阅读入口	3
2	三个首次定义	3
2.1	分布式攻击实验	3
2.2	多节点协同	3
2.3	跨节点关联	4
3	被挑战的核心假设	4
4	从单点防御到多节点实验	5
4.1	单攻击者、单提示、单模型、单回合	5
4.2	多节点、多角色、多轮、多目标	5
5	攻击路径的抽象阶段	6
6	Policy-Compliant Harm: 局部合规与全局破坏	6
7	复用 07: ASR 与 Recall	6
8	复用 09: Trace 到 workflow 图	7
9	跨模态风险: 文本之外的节点输入	8
10	实验设计蓝图	8
10.1	节点与角色	8
10.2	通道与边界	9
10.3	实验矩阵	9
11	防御框架: 从身份信任到内容感知	9
11.1	内容感知证明	10
11.2	序列感知 SOC	10
11.3	沙箱与最后一道闸	10
12	官方资料对本主题的校准	10
13	落地检查表	11
14	结语	11
	配图接入	12

1 本讲义的阅读入口

本主题由 Meta 讲者 Aditya 展开，核心问题很硬：企业 AI 已经从单个聊天窗口扩展成多代理、多工具、多通道的系统，但很多安全设计仍按单点应用来守。讲者把这一错位称为 AI 安全里的核心假设危机：一个被隔离的高权限 action agent，只要通过可信内部通道接收上游摘要，就会被默认视为安全节点。

这份讲义把演讲中的“multi-agent swarm”、“air-gapped action agent”、“payload laundering”、“policy-compliant harm”与“cross-agent workflow reconstruction”组织成一套可复盘的实验框架。它关注防御方如何设计实验、如何看见跨节点语义链路、如何把 07 主题的 ASR/Recall 与 09 主题的 Trace 复用到多代理场景。

transcript 前段还给出 Lavender、Gospel、Sharp-Eye network 等现实参照。讲义不展开这些系统的外部背景，只保留它们在本讲中的作用：多代理、跨模态、持续通信的 AI 系统已经进入军事、公共部门、监控与企业自动化等语境。这个现实参照让后续实验更具体，防守侧不能继续只按单聊天机器人建模。

安全边界说明：本文只讨论防御建模、评估指标、审计视图与工程治理。涉及 payload laundering、隐藏指令、跨节点传播等内容时，仅保留抽象机制与风险解释，避免给出可直接滥用的操作配方。

2 三个首次定义

2.1 分布式攻击实验

分布式攻击实验指一种安全评估设计：研究者把目标 AI 系统拆成多个节点、角色、通信通道与权限边界，观察攻击意图如何在多轮交互中被改写、摘要、转交、聚合，最终影响某个高价值动作或决策。它检验的对象超出某一次输入过滤是否失手，落点是整条工作流程能否识别“语义上已经变质的上下文”。

形式化地，可把实验写成一个有向图：

$$G = (V, E), \quad V = \{v_1, \dots, v_n\}, \quad E \subseteq V \times V$$

其中 V 是代理、模型、工具、日志系统、执行端等节点， E 是消息、摘要、API 调用、文件交接或人工审批。攻击意图 I 在每条边上经过变换：

$$I_{t+1} = f_e(I_t, C_t, P_t)$$

C_t 表示上下文， P_t 表示策略约束或格式约束。危险点在于： f_e 可能把显眼的恶意痕迹压缩成看似合规的业务摘要，同时保留足够的语义方向。

2.2 多节点协同

多节点协同指多个代理或服务节点按角色分工完成任务：例如外网研究代理抓取网页，分析代理整理结论，内网 action agent 根据摘要调用高权限接口。每个节点只看到局

部上下文，局部行为也可能完全合规；问题出在这些局部合规动作经过组合后，形成全局风险。

这与传统“单进程、单请求、单日志”的观察方式差异极大。传统防守像只看每个路口有没有闯红灯；多节点协同风险更像城市交通里所有车都守规矩，但导航系统把车流一起引向错误终点。单车视角没有异常，路网视角才出现模式。

2.3 跨节点关联

跨节点关联指把不同代理、工具、日志、审批、输出之间的事件重新连成一条可解释链路。它复用 09 主题的 **Trace** 思想：Trace 是从需求、输入、上下文、工具调用、文件变化、测试输出到发布或执行动作的完整轨迹。在主题 10 中，Trace 从“单次 AI coding 行为”扩展为“跨代理 workflow 轨迹”：

$$\text{Trace}_{\text{multi}} = \langle e_1^{v_a}, e_2^{v_b}, e_3^{v_c}, \dots, e_k^{v_z} \rangle$$

其中 $e_i^{v_j}$ 表示节点 v_j 上发生的第 i 个事件。防御方要回答的关键问题是：这些事件分别看起来正常时，合起来是否形成了异常的语义迁移。

3 被挑战的核心假设

演讲从一个企业架构出发：外网研究代理面向互联网，分析代理做摘要和整理，action agent 位于隔离区或高权限区，通过可信内部通道接收上游结果。很多组织会自然认为：外网入口被过滤，内部通道有身份认证，action agent 还处在 air gap 环境中，系统就足够稳。

讲者指出，风险落在“可信关系”的组合处。mTLS、NHI（non-human identity，非人类身份）、API 凭证、内部 REST/gRPC 通道验证了“谁在通信”，却未必验证“通信内容在语义上发生了什么”。身份可信与内容可信是两层概念：前者像门禁卡，说明来人有资格进门；后者像货物安检，说明箱子里的东西符合预期。多代理系统常常把门禁卡检查得很严，却让箱子在内部通道中一路免检。

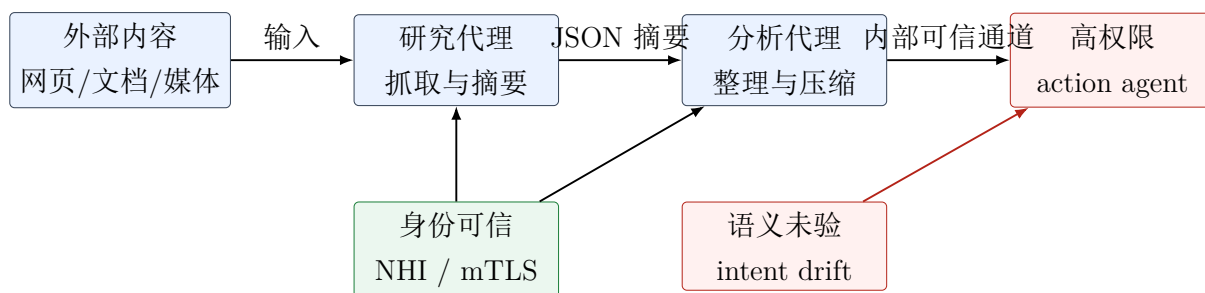


图 1: 主题 10 的核心架构：身份链路变绿，不代表语义链路同样变绿。

4 从单点防御到多节点实验

4.1 单攻击者、单提示、单模型、单回合

很多 AI 安全测试默认四个单点假设：

1. **单攻击者**：攻击流量来自一个可识别来源。
2. **单提示**：危险内容集中在一个 prompt 或一个输入对象中。
3. **单模型**：一个模型完成理解、规划与执行判断。
4. **单回合**：检测器只需判断当前输入是否越界。

这些假设降低了测试成本，却也让防御方误以为“每个局部输入都合规”等同于“全局行为也合规”。分布式实验要故意打破这四个假设。

4.2 多节点、多角色、多轮、多目标

主题 10 的实验结构可拆成四个维度。

维度	实验含义	防御方应观察的信号
多节点	研究代理、分析代理、执行代理、日志节点、审批节点共同参与	数据在节点间的来源、摘要、变换、权限变化
多角色	每个节点有不同职责和权限，外网节点低权限，内网节点高权限	低权限内容是否被高权限节点当作可信事实使用
多轮交互	攻击意图经过抓取、摘要、重写、聚合、执行多个阶段	意图是否在压缩后保留方向，在格式上变得更干净
多目标评估	同时衡量攻击成功、检测召回、覆盖率、成本、延迟、可复盘性	指标是否只优化单点拦截，遗漏跨节点重建

可把多轮过程写成：

$$S_0 \xrightarrow{v_1} S_1 \xrightarrow{v_2} S_2 \xrightarrow{v_3} S_3 \xrightarrow{v_4} A$$

S_i 是第 i 轮上下文状态， A 是最终动作。单点检测器通常只看 S_i 是否出现禁用词或恶意格式；分布式实验要求检查 $S_0 \dots S_3$ 的语义梯度是否逐步靠近危险动作。

5 攻击路径的抽象阶段

讲者把核心现象称为 payload laundering，即负载清洗或意图洗白。这里的“洗白”超出文件加密、编码绕过之类的单纯格式变化，重点是语义在 LLM 摘要、压缩和转述中被重包装：表面变成干净的 JSON、报告摘要或业务指令，内核仍推动下游执行偏离预期。

为了避免操作化细节，本文只保留阶段模型。

1. **进入阶段**：外部内容进入研究代理的可见范围。内容可以是网页、文档、图像、音频或视频。
2. **转写阶段**：研究代理把内容整理成结构化摘要，例如 JSON、报告段落或事件记录。
3. **传递阶段**：摘要通过内部可信通道进入分析代理或 action agent。
4. **解释阶段**：下游代理把摘要当作正常业务上下文解释，潜在意图被映射为候选动作。
5. **执行阶段**：高权限节点完成 API 调用、删除、审批、调度或其他敏感动作。

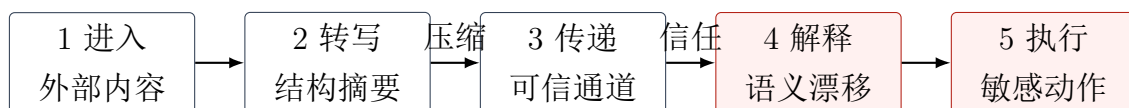


图 2: 负载清洗的防御抽象图：危险从格式问题转化为语义链路问题。

6 Policy-Compliant Harm: 局部合规与全局破坏

演讲中反复出现的概念是 **Policy-Compliant Harm** (PCH, 可译为“策略合规伤害”)。它描述一种尴尬场景：每个节点的单步行为都符合本地策略，日志里每条记录都像“绿灯”，但所有步骤组合后产生破坏性结果。

一个简化判断式如下：

$$\forall i, \text{policy}(e_i) = \text{allow} \quad \wedge \quad \text{Impact}(\text{compose}(e_1, \dots, e_k)) \gg 0$$

这里的 `compose` 是组合函数。PCH 的难点在于，它的恶性性常常藏在组合关系中，而不藏在任何单条事件里。传统 IOC (indicator of compromise, 失陷指标) 偏好原子证据，例如可疑 IP、哈希、命令、异常登录。PCH 场景里，证据更像拼图：单块看起来普通，拼完才看到图案。

7 复用 07: ASR 与 Recall

07 主题首次定义了 ASR；本主题直接复用。对分布式攻击实验而言：

$$\text{ASR} = \frac{\text{触发目标风险结果的实验次数}}{\text{总实验次数}}$$

分母不能只按单条 prompt 计数，应按完整 workflows 计数。例如一次实验包含外部内容进入、摘要、跨节点传递、action agent 判断和最终动作。只要其中某个环节被拦截，实验就应记为未成功或部分成功。

Recall 也从 07 主题复用：

$$Recall = \frac{TP}{TP + FN}$$

其中 TP 是被正确识别的分布式风险链， FN 是漏掉的风险链。多节点场景中， FN 的含义更尖锐：检测器可能发现每个节点都正常，于是把整条链漏掉。此时高 Recall 需要跨节点关联能力，而非只靠输入过滤器。

指标	单点场景	分布式场景
ASR	一条输入是否绕过模型或过滤器	一条工作流是否把语义意图送达高权限动作
Recall	检测器是否识别当前恶意样本	SOC 是否重建跨代理、跨模态、跨时间的风险链
覆盖率	测试多少 prompt 类型	覆盖多少节点、边、角色、通道和权限转换
延迟	单次响应耗时	从源头事件到风险告警的跨节点检测时间
成本	生成和评估样本成本	采集 Trace、存储日志、语义关联与人工复核成本

8 复用 09：Trace 到工作流图

09 主题的 Trace 关注 AI coding 从需求到提交的证据链。主题 10 把 Trace 提升为 **agent workflow graph**：每个节点要记录输入来源、变换方式、输出语义、权限上下文和下游接收方。

一个最小 Trace 字段可包含：

- **source**: 内容来自外部网页、内部文档、人工输入、模型输出或工具返回。
- **transform**: 节点做了摘要、翻译、重写、压缩、分类、提取或聚合。
- **semantic_claim**: 输出声称表达的业务含义。
- **privilege_context**: 当前节点的身份、权限、网络位置和可调用工具。
- **sink**: 输出进入的下游节点或敏感动作。

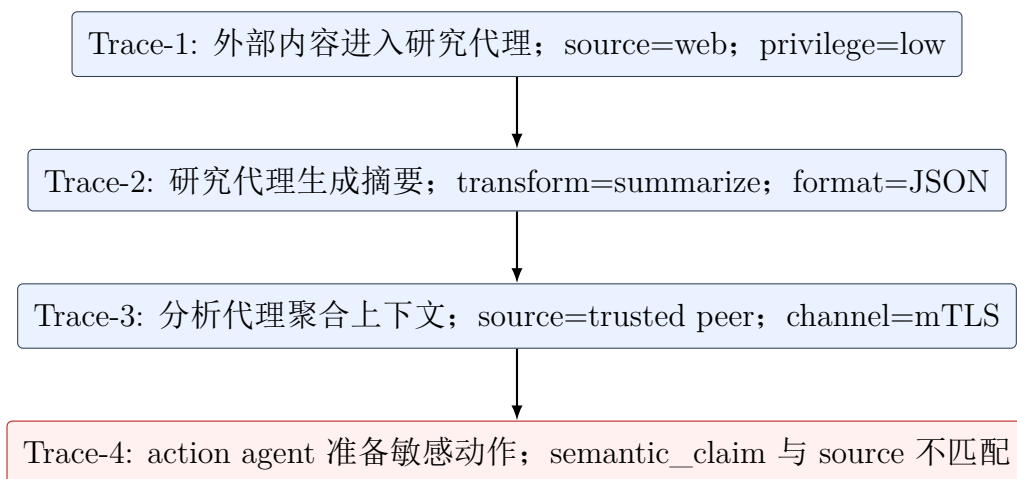


图 3: 跨代理 Trace: 风险证据出现在链路关系中, 而非单条日志中。

9 跨模态风险：文本之外的节点输入

演讲后半段把攻击面扩展到图像、音频和视频。多模态系统常把图像帧、音频片段、文档和结构化数据融合给同一个 LLM 或下游代理。风险因此从“文本输入过滤”扩展成“模态融合后的语义漂移检测”。

这里应避免一种常见误判：输入一旦转成图像、音频或视频，防御方就低估其语义作用。多模态模型会把像素、频谱、帧序列转成内部语义表示。若不同模态各自只携带一小段意图，聚合层可能把它们拼成完整指令。类比拼图更准确：单块拼图没有图案，拼在一起才显形。

防御方需要在三层做检查：

1. **模态入口层**：检查每种输入是否与业务目的匹配，是否存在异常隐藏内容或不必要的复杂格式。
2. **语义聚合层**：检查聚合后的摘要是否产生新意图，尤其是输入中没有明示授权的敏感动作。
3. **执行确认层**：在 action agent 执行前，把来源、变换、语义声明与目标动作做一致性验证。

10 实验设计蓝图

10.1 节点与角色

一个防御型分布式实验至少需要四类节点：

- **外部内容节点**：模拟网页、文档、媒体流、工单或第三方数据源。
- **研究节点**：负责抓取、摘要、初筛，通常面向外网，权限较低。

- **分析节点：**负责聚合多源信息，输出结构化结论。
- **动作节点：**负责调用内部接口、变更配置、删除记录、发起审批或执行任务，权限最高。

实验的目标应放在测量系统能否在每次跨节点传递时保留来源与语义证明，避免沦为“看谁能绕过过滤器”的表演。所有样本、节点、日志和判定规则都应预先登记，避免把红队演示变成不可复盘的舞台效果。

10.2 通道与边界

通道至少标注四个属性：

- **身份层：**谁向谁发送，使用何种 NHI、mTLS、service account 或审批身份。
- **内容层：**发送了什么语义内容，是否包含摘要、引用、附件或模型生成文本。
- **权限层：**接收者能做什么，是否能触发高影响动作。
- **观测层：**日志记录到什么粒度，能否重建跨节点路径。

10.3 实验矩阵

实验轴	可变参数	观察问题
节点数量	2、3、5 个代理	路径增长后，Recall 是否明显下降
角色分工	研究、分析、执行、审批	哪个角色最容易把外部语义当作内部事实
交互轮次	1、3、5 轮摘要与转述	语义是否在压缩后保留危险方向
通道类型	REST、gRPC、消息队列、文件交接	通道日志是否包含内容证明与变换证明
模态类型	文本、图像、音频、视频、混合	聚合层是否能发现跨模态意图拼合
目标类型	读取、写入、删除、审批、发布	敏感动作是否需要额外语义确认

11 防御框架：从身份信任到内容感知

主题 10 的防御结论可以压缩成一句话：企业要从“谁发送了消息”升级到“消息经过了哪些变换，并且语义是否仍符合上游授权”。

11.1 内容感知证明

内容感知证明可以看作给每次代理输出附上一张“语义报关单”。它至少声明：

- 输入来源属于外部、内部、人工或工具返回。
- 当前节点做了何种变换。
- 输出的语义边界是什么。
- 输出是否允许被下游当作执行命令。
- 下游若要执行敏感动作，需要哪些额外确认。

跨代理场景可以采用“来源到敏感动作”的分析方式：把外部内容、摘要、工具返回和其他代理输出视为来源，把发布、外发、权限变更、生产动作视为敏感汇点，中间每一次变换都要留下 Trace。

11.2 序列感知 SOC

传统 SIEM/SOC 常偏向无状态关联：同一账号、同一主机、同一 IP、同一时间窗口。多代理系统需要 **sequence-aware SOC telemetry**，也就是按工作流序列观察：

external source → summary → trusted peer → privileged action

若某条链路从外部低信任内容一路变成高权限动作，哪怕中间每一步都用合法身份完成，也要进入人工复核或自动阻断。

11.3 沙箱与最后一道闸

沙箱、文件系统隔离、网络隔离与越界审批可以作为 action agent 的最后一道闸。但沙箱只能限制可达范围，无法替代跨节点语义关联。一个 action agent 即使被关在隔离区内，仍可能在授权边界内执行错误动作。隔离解决“能碰到什么”，语义验证解决“为什么要碰”。

12 官方资料对本主题的校准

本讲义只使用 official_references.md 中允许的官方资料做概念校准：

- OpenAI 的 red teaming 资料指出，红队可由人工、自动化和混合方法组成，自动化方法适合规模化生成测试样例，结果应沉淀为安全评估。
[OpenAI: Advancing red teaming with people and AI]
- Anthropic 的前沿威胁红队资料强调先定义 threat model，再由领域专家与 LLM 专家反复探索能力边界，并把发现转化为可重复评估和缓解措施。
[Anthropic: Frontier Threats Red Teaming]

- Google Project Zero 与 DeepMind 的 Big Sleep 实践展示 LLM 辅助漏洞研究如何形成假设、调试失败、构造复现输入并输出根因分析。[Google: From Naptime to Big Sleep]

13 落地检查表

1. **画图**: 列出所有代理、工具、模型、队列、日志、审批、执行端, 形成 $G = (V, E)$ 。
2. **标权**: 给每个节点标注权限、身份、网络位置、可调用工具和敏感动作。
3. **标源**: 每条消息记录 source、transform、semantic_claim、sink。
4. **测链**: 按 workflow 计算 ASR、Recall、覆盖率、成本、延迟, 而非只测单 prompt。
5. **验义**: 对进入 action agent 的摘要做内容感知证明与语义漂移检测。
6. **建 Trace**: 用跨代理 Trace 重建每次敏感动作的来源与变换链。
7. **设闸**: 对删除、发布、审批、外发、权限变更等动作加入执行前确认。
8. **复盘**: 把漏报链路转化为新测试样例, 进入下一轮红队评估。

14 结语

主题 10 真正刺中的地方, 是企业 AI 安全的观察粒度。单个模型、单条输入、单次 API 调用都可能看起来干净; 系统风险却在节点之间流动, 在摘要中换装, 在可信通道里升级权限, 在 action agent 前完成最后拼接。

分布式攻击实验的价值, 正是把这种“组合后才显形”的风险拉回工程视野。防御方需要接受一个朴素事实: 多代理系统的安全边界已经从应用边界扩展为 workflow 边界。能画出节点, 能重建 Trace, 能解释语义如何跨节点迁移, 才有资格谈真正的 AI 安全运营。

配图接入



图 4: 被利用的核心假设：截图列出“单个 Agent 与外部互联网隔离就安全”等前提，适合引入分布式攻击实验。这里的风险来自多节点协同：每个节点看似局部合规，组合后可能形成跨上下文、跨通道的攻击路径。¹

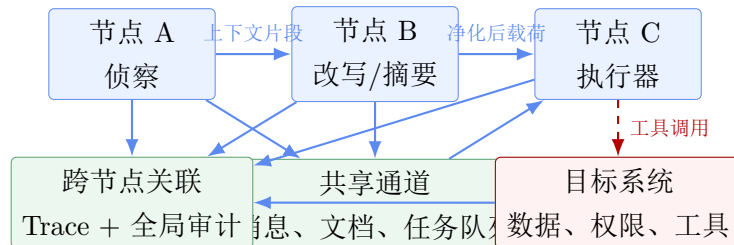


图 5: 分布式攻击实验拓扑图：节点 A 负责侦察，节点 B 负责改写或摘要，节点 C 负责执行，通道负责传递上下文，目标系统承受最终工具调用。跨节点关联把分散事件重新拼成一条 Trace，用来识别单点视角看不到的协同风险。²

参考资料

1. OpenAI, *Advancing red teaming with people and AI*. <https://openai.com/index/advancing-red-teaming-with-people-and-ai/>
2. Anthropic, *Frontier Threats Red Teaming for AI Safety*. <https://www.anthropic.com/news/frontier-threats-red-teaming-for-ai-safety>

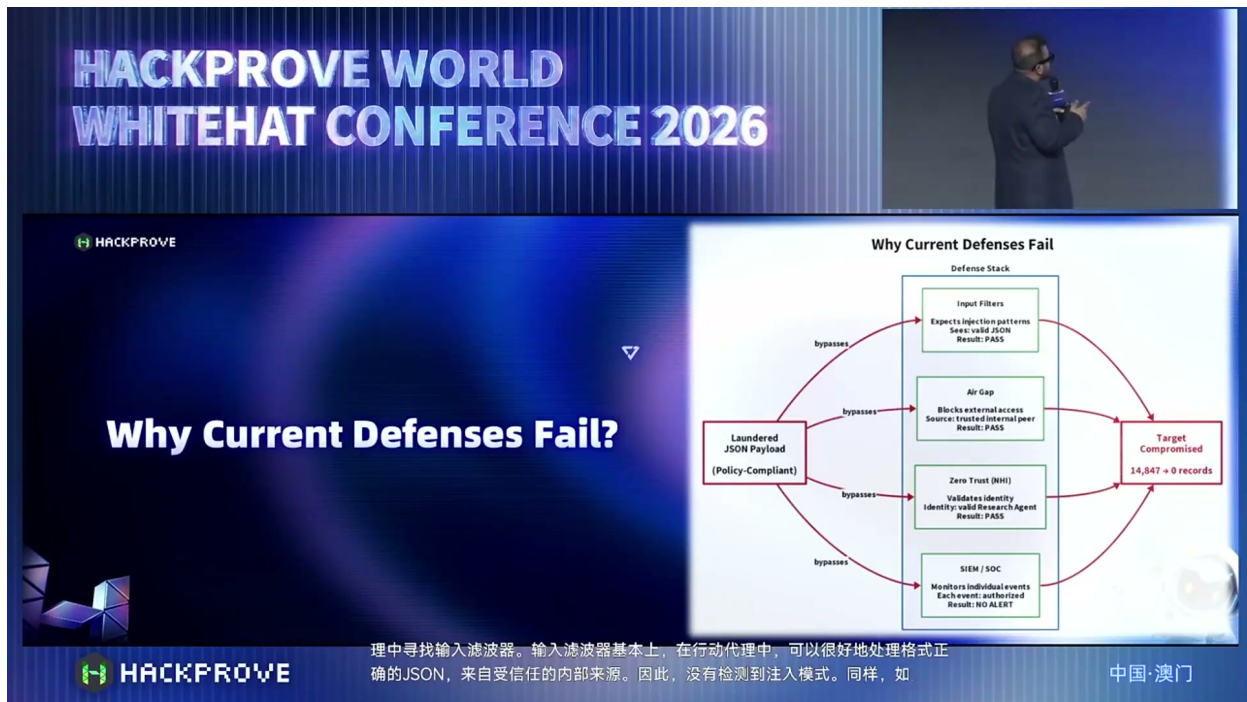


图 6: 当前防御失效的路径图: 截图展示多个输入源绕过单点边界后汇入目标应用。它说明单模型、单提示、单回合的评估过窄; 分布式实验要同时看角色、通道、时间顺序和最终目标。³

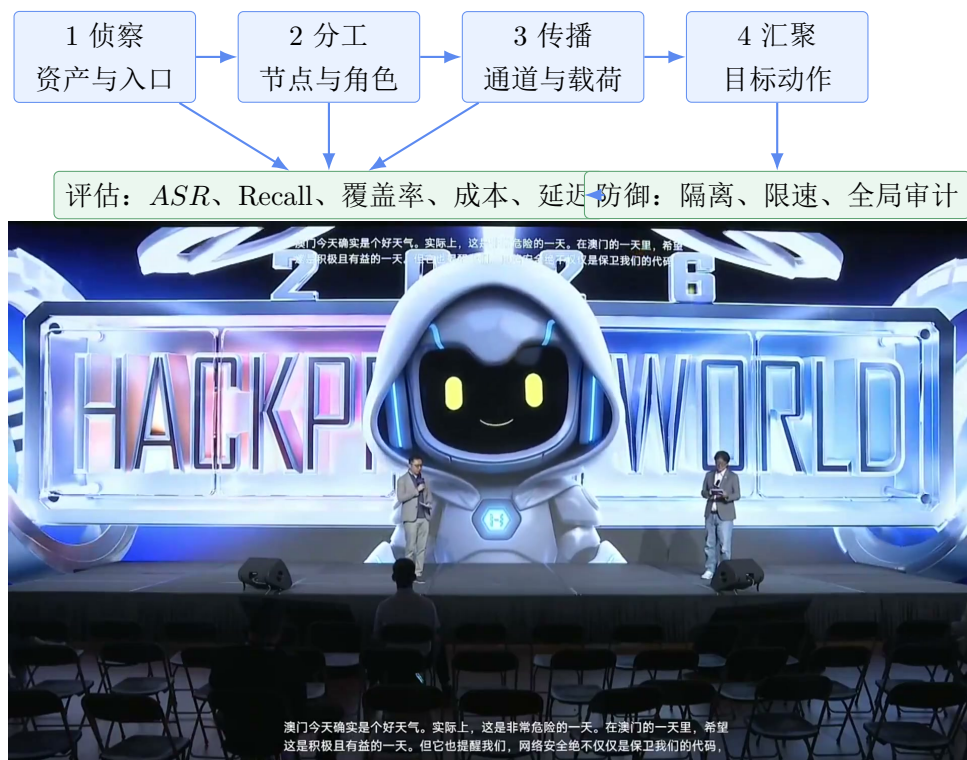


图 7: 攻击阶段图与现场收束: 分布式实验按侦察、分工、传播、汇聚推进, 再用 $ASR = \frac{\text{成功攻击次数}}{\text{攻击尝试次数}}$ 与 Recall 检查攻击有效性和防御漏报。下方现场图可作为章节结尾, 提示实验结论要回到隔离、限速、跨节点关联和全局审计。⁴

3. Google Project Zero, *From Naptime to Big Sleep*. <https://projectzero.google/2024/10/from-naptime-to-big-sleep.html>